



Pretexting



What is Pretexting?

- Pretexting is the process of creating a false pretext or scenario to gain the trust of targets and extract sensitive information. This may involve impersonating authority figures, colleagues, or service providers to manipulate victims into divulging confidential data.
- Simply put, it is putting someone or an employee in a familiar situation to get them to divulge information.
- Unlike other forms of social engineering that rely on deception or coercion, pretexting involves the creation of a false narrative or context to establish credibility and gain the trust of the target.

Characteristics of Pretexting

- False Pretense: The attacker creates a fictional story or pretext to deceive the target into believing that the interaction is legitimate and trustworthy. This pretext often involves impersonating someone with authority, expertise, or a legitimate reason for requesting information or assistance.
- Establishing Trust: The attacker uses the pretext to establish rapport and build trust with the target. This may involve leveraging social engineering techniques, such as mirroring the target's language, tone, and behavior, to create a sense of familiarity and connection.

Characteristics of Pretexting

- **Manipulating Emotions:** Pretexting often exploits human emotions, such as curiosity, fear, urgency, or sympathy, to manipulate the target's behavior. By appealing to these emotions, the attacker can influence the target's decision-making process and increase compliance with their requests.
- **Information Gathering:** Once trust is established, the attacker seeks to extract sensitive information or access privileges from the target. This may involve posing as a trusted entity (e.g., colleague, vendor, service provider) and requesting information under the pretext of a legitimate need or emergency.

Characteristics of Pretexting

- Maintaining Consistency: To maintain the illusion of legitimacy, the attacker ensures that the pretext remains consistent and plausible throughout the interaction.
- This may require careful planning, research, and improvisation to adapt to the target's responses and maintain credibility.

Pretexting Examples

- Tech Support Scam: An attacker poses as a technical support representative from a legitimate company and contacts individuals, claiming that their computer is infected with malware. The attacker convinces the target to provide remote access to their computer or install malicious software under the pretext of fixing the issue.
- Job Interview Scam: An attacker pretends to be a recruiter or hiring manager from a reputable company and contacts job seekers, offering them fake job opportunities or conducting fraudulent job interviews. The attacker may request sensitive personal information or payment under the pretext of processing the job application.

Pretexting Examples

- Emergency Situation: An attacker fabricates an emergency situation, such as a security breach, data leak, or system outage, and contacts employees, requesting immediate assistance or information. The attacker exploits the target's sense of urgency and concern to extract sensitive information or gain access to systems under the pretext of resolving the emergency.

Importance and Impact

- Pretexting can be highly effective in bypassing technical controls and exploiting human vulnerabilities within organizations. It relies on psychological manipulation and social engineering tactics to deceive targets and achieve malicious objectives.
- Pretexting attacks can lead to data breaches, financial losses, reputational damage, and regulatory penalties for organizations. Therefore, it is essential for organizations to raise awareness about pretexting techniques, implement robust security policies and procedures, and provide training to employees to recognize and mitigate social engineering attacks.

Pretexting Templates/Samples

Corporate IT Department Upgrade:

- Pretext: The attacker impersonates a member of the company's IT department and sends an email to employees, claiming that the company's email system is being upgraded. The email instructs recipients to click on a link to update their email settings to avoid service disruptions.
- Objective: To trick employees into clicking on the malicious link, which leads to a phishing website where they are prompted to enter their email credentials, allowing the attacker to steal their login information.

Pretexting Templates/Samples

<!-- PRETEXT OVERVIEW:

Credential capture.

\$organization: Target organization.

\$evilurl: URL to cloned Office 365 portal.

\$evildomain: Spoofed domain.

Can be sent as helpdesk@domain.com.

Don't forget to setup the mailbox for user replies!

-->

Subject: New Webmail - Office 365 Rollout

Dear colleagues,

In an effort to continue to bring you the best available technology, \$organization has implemented the newest version of Microsoft's Office 365 Webmail.

Your existing emails, contacts, and calendar events will be seamlessly transferred to your new account.

Visit the [new webmail website](\$evilurl) and login with your current username and password to confirm your upgraded account.

If you have additional questions or need clarification, please contact the Help Desk at helpdesk@\$evildomain.

Thank you,

References & Resources

- A library of pretexts to use on offensive phishing engagements:
<https://github.com/L4bF0x/PhishingPretexts/tree/master>



Thank You!